DIGITAL TRUST FUTURES
FOUNDATION

DIGITAL SOVEREIGNTY IN PRACTICE

The Localisation Trap

Why data protection law needs technical control

Digital Sovereignty Series | Article 5 of 6

Why this matters now

Local hosting solves a residency problem, not automatically a sovereignty problem. This article separates where citizens' data sits from who can technically make it intelligible, and sets out the key custody, logging and procurement controls that turn data protection law into control a country can actually enforce.

Prepared by Godfrey Kutumela, Digital Trust Futures Foundation

6 November 2026 | Series version 1.0 | Classification: Public

Contents

Executive summary	3
1. PII is the load-bearing concept	5
2. Where data protection and sovereignty reinforce each other	6
3. Where law alone is not enough	8
4. The localisation fallacy	10
5. The honest formulation for government leaders	12
6. From principle to procurement: a decision path	14
Series bridge	15
About the author	15
About Digital Trust Futures Foundation	16
References and further reading	17

About this edition

This edition updates the June 2026 original for developments since: the lapse of FISA Section 702, the EU's proposed Cloud and AI Development Act, the pending appeal on the EU–US Data Privacy Framework, and provider testimony to a French Senate inquiry.

It is general analysis, not legal advice. Confirm legal and regulatory status with counsel before acting.

Executive summary

Digital sovereignty and data protection are often discussed as separate disciplines, one concerned with infrastructure and geopolitics, the other with privacy compliance. For citizens whose biometric, identity, health, welfare or payment data sits inside digital public infrastructure (DPI), they face the same practical question: **who can access this data, under what authority, and can the state actually prevent unauthorised or extraterritorial access?**

This article addresses the most common sovereignty misconception: that local hosting equals control. Data residency can be valuable, but it does not remove legal access through foreign corporate jurisdiction unless technical safeguards such as external key custody, confidential computing and verifiable access controls support it. In the cloud era, a country's data protection law and the technical architecture of its systems must be designed together.

2018	12 Jun 2026	4 levels	31 May 2024
US CLOUD Act: reach follows possession, custody or control, not location	FISA Section 702 lapsed; collection runs on court certifications to about March 2027	Assurance tiers in the EU's proposed Cloud and AI Development Act	South Africa publishes its National Policy on Data and Cloud

Key points for policymakers and DPI leaders

- PII protection is where sovereignty commitments are either made real or exposed as merely legal language.
- Purpose limitation, minimisation, cross-border transfer controls and breach notification all reinforce sovereignty, but they cannot neutralise foreign compulsion orders on their own.
- Local hosting solves a residency problem, not automatically a sovereignty problem.
- Countries should distinguish clearly between where data sits and who can technically make it intelligible.

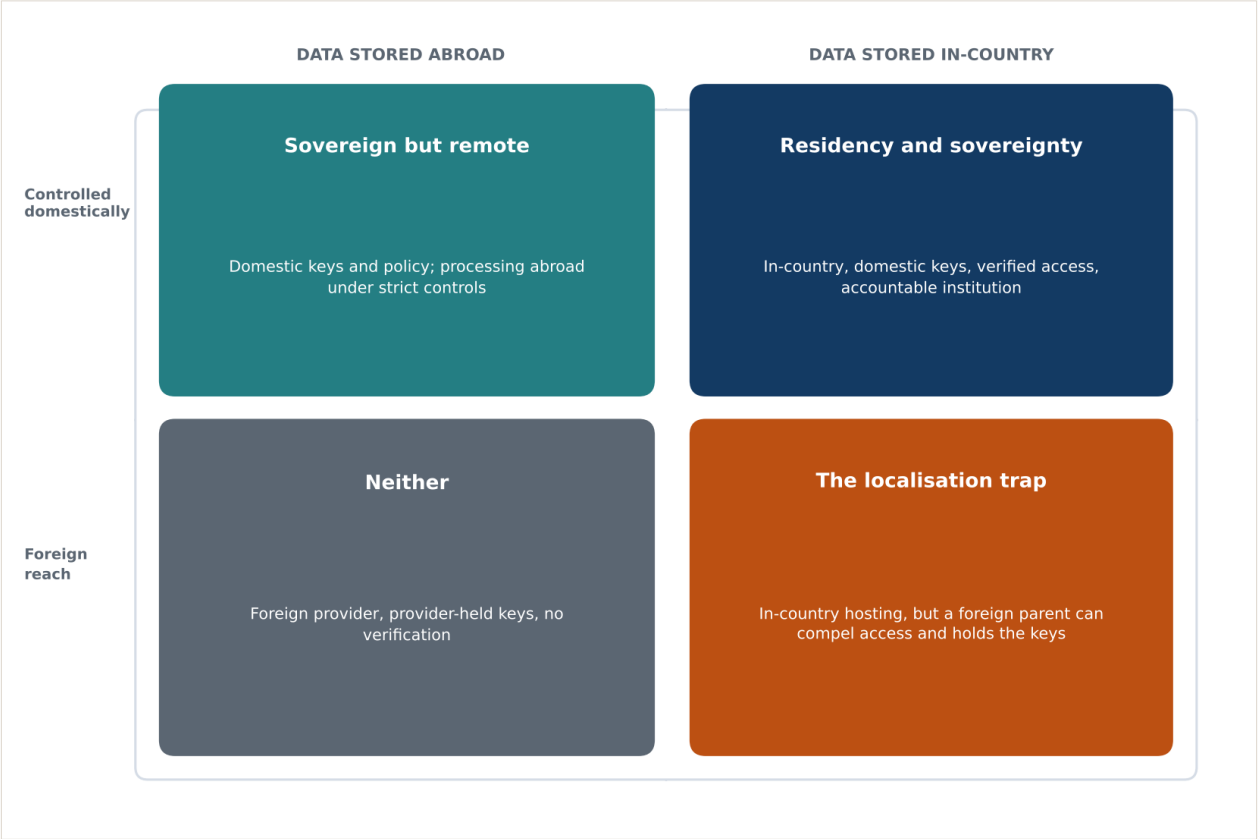


Figure 1. Residency and sovereignty are different questions: where the data sits, and who controls and can compel it.

What has changed since the June 2026 edition

Several developments since the first edition sharpen, rather than soften, its argument. They are summarised below; the sources are listed in the reference section and should be checked against primary texts before any official use.

Development	What changed	Why it matters here
US FISA Section 702	The statute lapsed on 12 June 2026, the first lapse since 2008. Collection continues under court certifications approved on 17 March 2026, which run to about March 2027. Reauthorisation was unresolved in late October 2026 [14][15].	Legal exposure has not disappeared; it has become more uncertain. Technical control does not depend on how Congress votes.
EU Cloud and AI Development Act (CADA)	Proposed on 3 June 2026: a four-level cloud sovereignty framework linked to public-sector use, still in negotiation [16][17].	Governments are turning sovereignty into procurement criteria with graduated assurance.
EU–US Data Privacy Framework	Upheld by the EU General Court on 3 September 2025; an appeal (C-703/25 P) is pending; in July 2026 the European Data Protection Board asked the Commission to assess whether its functioning is affected [18].	Adequacy is a legal arrangement that can change; architectures that survive its loss are more resilient.

Development	What changed	Why it matters here
Provider testimony	In June 2025, Microsoft France told a French Senate inquiry under oath that it could not guarantee EU citizens' data would never be transmitted to US authorities [19].	Even a major provider cannot promise what its own jurisdiction may require.

Table 1. Developments since June 2026.

1. PII is the load-bearing concept

The sovereignty debate can sound abstract when discussed in terms of cloud regions, procurement rules and national strategy. It becomes concrete when viewed through the citizen's record. Biometric identifiers, national ID numbers, payment histories, health information, welfare eligibility data and consent tokens are personally identifiable information (PII). Sovereignty is therefore ultimately about whether the state can protect people's data under real-world legal and technical pressure.

The operational question is simple: who can access this record, under what authority, and can the country that collected it **prevent** unauthorised or extraterritorial access, rather than merely object after the fact?

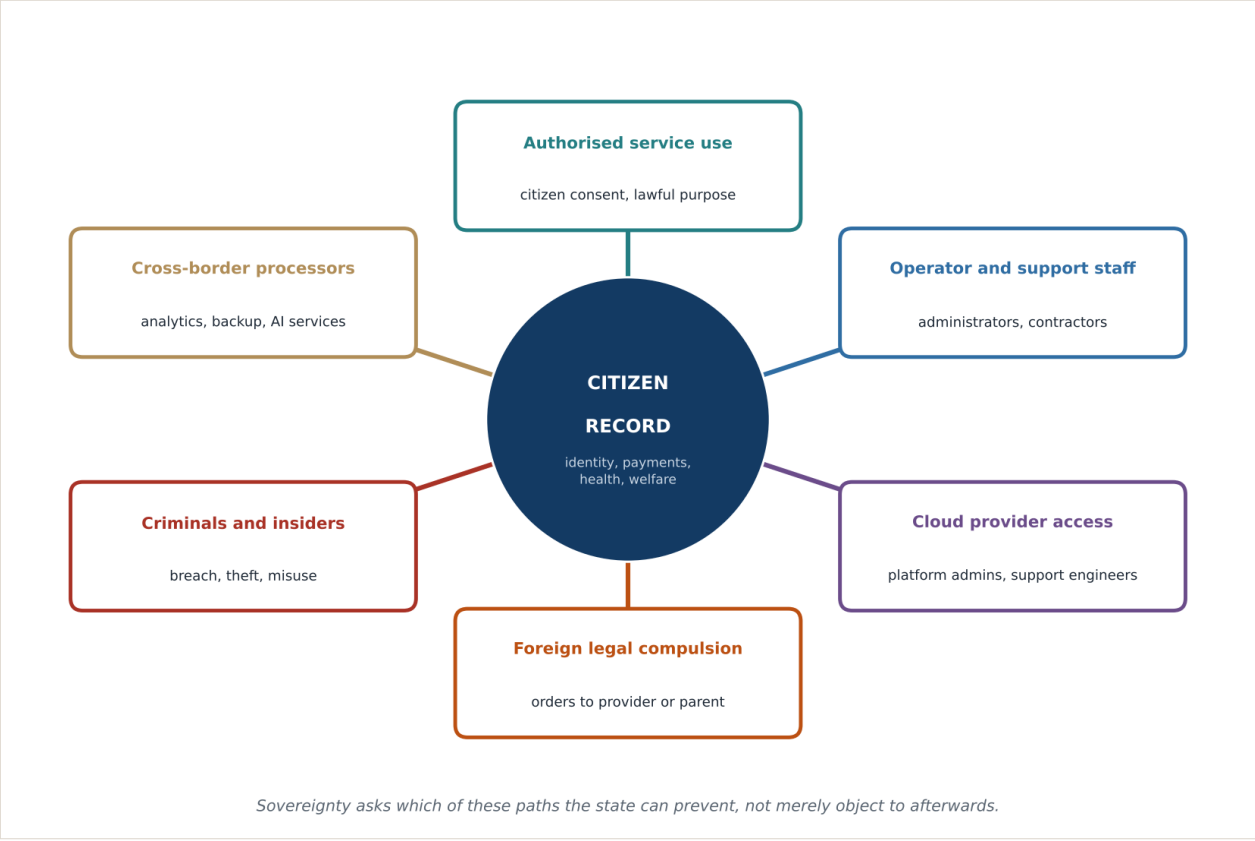


Figure 2. Six paths to a citizen record: sovereignty concerns the paths the state can prevent, not only those it can lawfully authorise.

Why DPI records are different

Record type	Why loss of control is serious	Control emphasis
Biometric identifiers	Fingerprints, iris and face templates cannot be reissued; compromise is permanent.	Template protection, no raw export, strictly limited processors.
National ID and civil registry data	The root of identity for every other service; population-scale aggregation reveals who people are and where they live.	Key custody by a domestic institution; tight administrative access.
Payment and transaction histories	Reveal behaviour, associations and finances; useful for targeting and coercion.	Minimisation, pseudonymous identifiers, audit of every look-up.
Health and welfare eligibility data	Expose vulnerability and entitlement; misuse harms the most exposed people.	Purpose limitation; separate stores; strong redress routes.
Consent tokens and logs	Show relationships between people and services; the audit trail is itself personal data.	Integrity protection; independent logging.

Table 2. Record types and what is at stake.

Three features make DPI different from ordinary enterprise data. **Scale:** one platform may hold the records of most of a population. **Permanence:** some identifiers cannot be changed after compromise. **Dependence:** citizens often cannot opt out of essential services, so failures of control are failures of the public trust that sustains adoption. These features turn data protection from a compliance task into a question of national resilience.

2. Where data protection and sovereignty reinforce each other

Data protection law already contains many legal building blocks for sovereignty: lawful basis, purpose limitation, minimisation, cross-border transfer controls, individual rights and breach notification. When these principles are technically enforced, they become sovereignty controls.

Data protection principle	Sovereignty function it performs	What makes it enforceable
Purpose limitation	Constrains what a foreign processor, or a foreign government compelling that processor, can lawfully justify accessing data for, narrowing the practical target of extraterritorial requests.	Purpose-bound access policies and denial logs.
Data minimisation	Reduces the volume and sensitivity of PII exposed in any one processing operation or breach, reducing the consequence of any sovereignty failure.	Selective disclosure; pseudonymous tokens.
Cross-border transfer restriction (for example GDPR Chapter V; POPIA section 72)	The direct legal expression of data sovereignty: a formal mechanism for a state to control where its citizens' data may lawfully travel.	Egress controls; regional key boundaries.

Data protection principle	Sovereignty function it performs	What makes it enforceable
Data subject rights (access, erasure, objection)	Gives citizens, not only the state, a recourse mechanism; failures are often first discovered through individual complaints.	Searchable audit trails and retrieval tooling.
Breach notification	Forces visibility. A sovereignty failure that is never disclosed is, from a policy standpoint, indistinguishable from a success; mandatory notification makes it observable.	Independent logging and tested incident processes.
Security safeguards	Requires technical measures proportionate to risk, which is where key custody and encryption become legal obligations.	Encryption with externally held keys; enclaves.
Accountability and assessment	Places responsibility on a named controller and requires impact assessment before risky processing.	A named institution accountable for key custody.

Table 3. Data protection principles and the sovereignty function each performs.

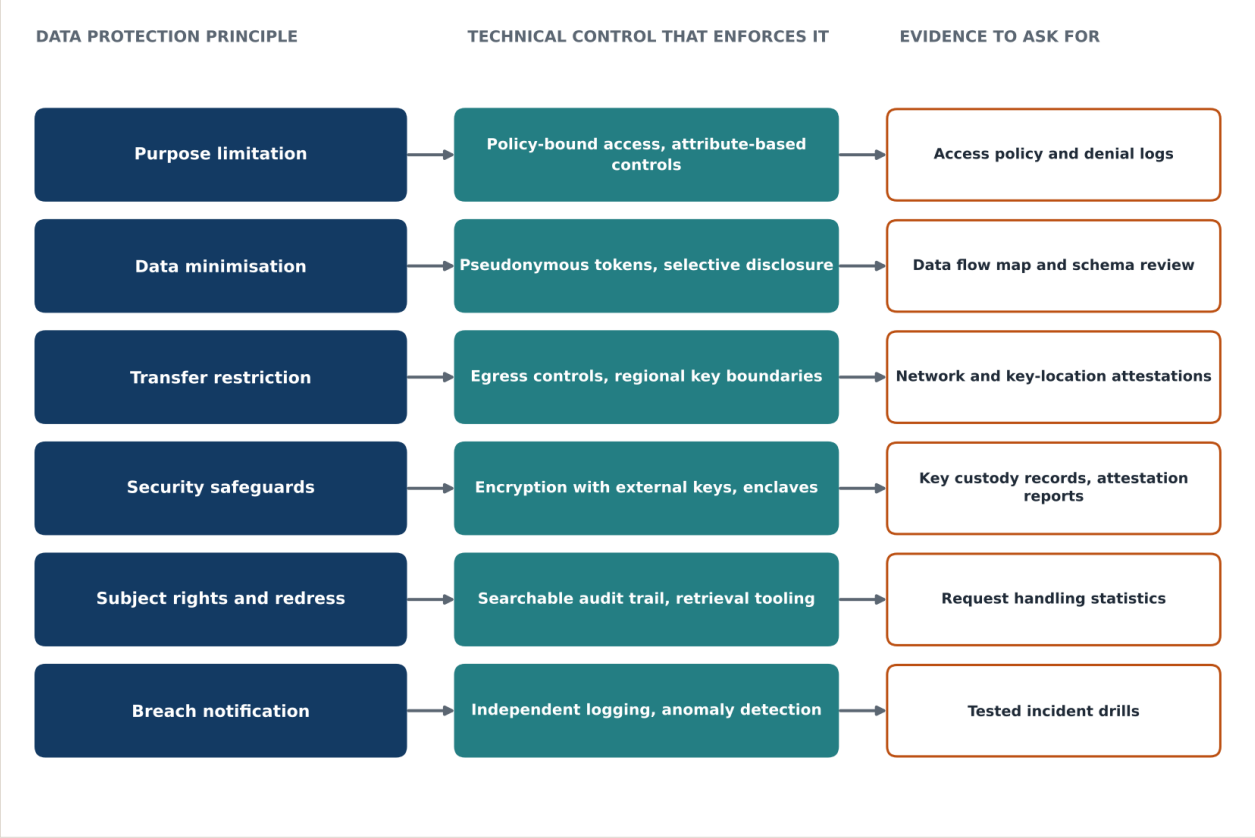


Figure 3. From legal principle to technical control to evidence a country can ask for.

The legal landscape that supports this

- **European Union.** GDPR Chapter V regulates transfers, and Article 48 provides that a third-country court or authority decision requiring transfer is recognisable only based on an international agreement.
- **South Africa.** POPIA section 72 restricts transfers of personal information to third parties in foreign countries unless the recipient is bound by adequate protection or another lawful basis applies. The National Policy on Data and Cloud (Cabinet approval 27 March 2024; published 31 May 2024) requires government data incorporating content on national security and sovereignty to be stored only in South African infrastructure, and imposes no further localisation requirement, leaving cross-border transfers to POPIA [20][21].
- **Elsewhere in Africa.** Reporting indicates that Nigeria's national guidelines require sovereign data to be hosted locally and its central bank has introduced localisation requirements for payments; that Rwanda requires localisation of sensitive financial, payment and telecommunications data; and that Kenya restricts certain transfers [22]. Rules differ and change, and should be checked for each jurisdiction.
- **Global.** The pattern is varied: some states legislate localisation, others regulate transfers, and others use procurement tiers, as the EU's proposed framework does.

> **The point to take from the law**
>
> These laws make a state's intent explicit. They do not by themselves determine what a foreign-controlled provider can be compelled to do. That depends on technical control, which the next section examines.

3. Where law alone is not enough

The gap is that domestic data protection law cannot automatically override a foreign government's lawful demand to a provider under that foreign government's own law. A contract clause, policy promise or local residency commitment may help, but it cannot by itself neutralise a legal authority directed at the provider or its parent company. Conflicts between legal systems are resolved by diplomacy, litigation, and often compliance by the provider with the demand that carries the greatest immediate penalty.

This is why technical enforcement matters. Encryption with externally held keys, confidential computing, strict access controls, independent logs and domestic or regional key custody change what can actually be disclosed, read or misused. **They turn a legal promise into an enforceable technical constraint.**

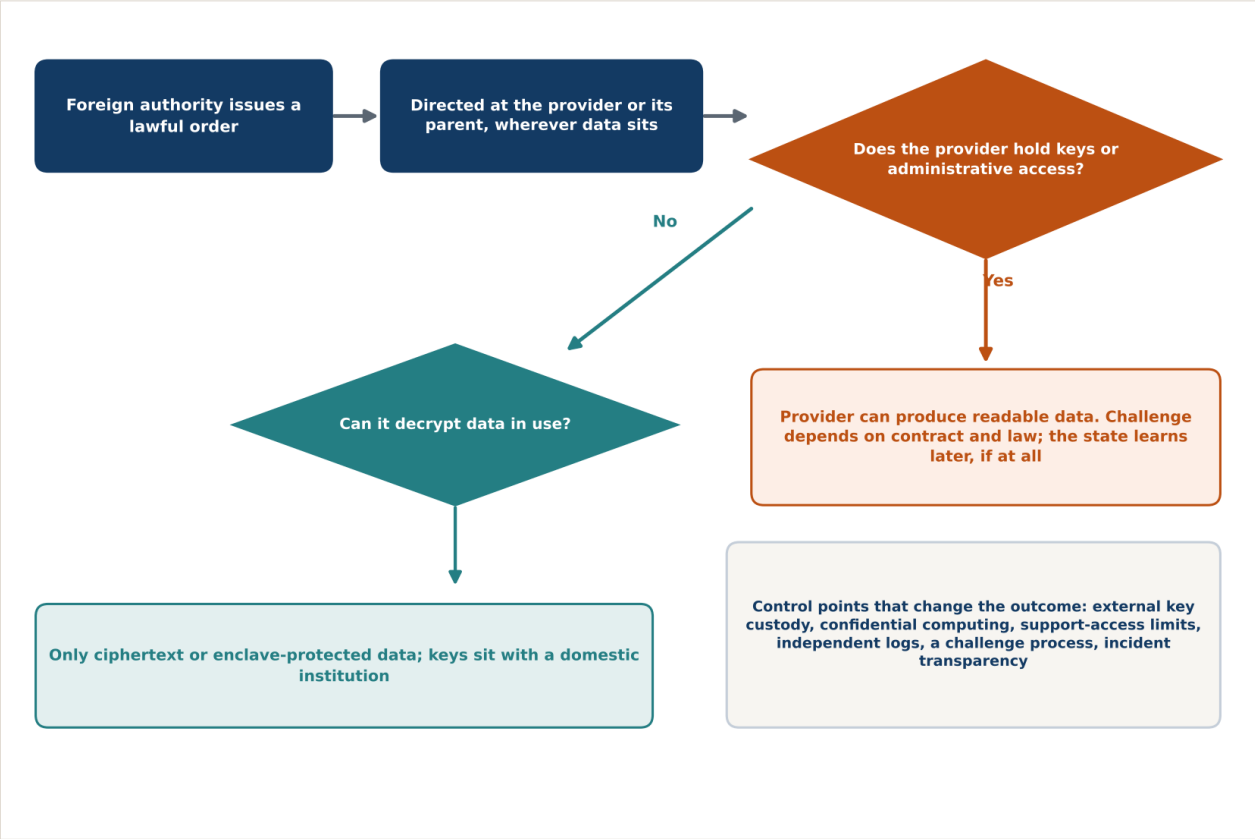


Figure 4. What a compelled disclosure can reach depends on who holds keys and administrative access, not on where the data sits.

What law can do, and what technology adds

Question	What law and contract can do	What technical control adds
Can the provider be told to hand over data?	Set notification, challenge and cooperation duties in the contract; assert domestic jurisdiction.	Ensure that what the provider holds is unreadable without a key it does not control.
Will the state learn about an access?	Mandate breach notification and audit rights.	Independent, tamper-evident logging that the provider cannot silently edit.
Can staff of the provider reach the data?	Prohibit support access except under agreed procedure.	Approval workflows, just-in-time access, customer lockbox, geographic and personnel restrictions.
Can the state leave?	Require portability and exit assistance.	Customer-held keys and tested export, so exit does not depend on the provider's goodwill.

Table 4. Complementary roles of legal and technical controls.

The evidence of fragility

- **Provider testimony.** Microsoft France's June 2025 statement under oath shows that even when data is stored in the EU, a provider subject to US law cannot promise to exclude US access [19].
- **Adequacy is conditional.** The EU–US Data Privacy Framework rests largely on a US executive order, faces a pending appeal, and has seen its oversight board lose its quorum; the EDPB asked the Commission in July 2026 to assess whether its functioning is affected [18].
- **Legal change cuts both ways.** The lapse of FISA Section 702 does not end US collection under existing certifications, and Executive Order 12333 is unaffected; a future reauthorisation may add or remove safeguards [14][15].

> **A caution**
>
> External keys and enclaves are not a magic shield. A key manager inside the same jurisdiction as the compelled provider does not help; keys held outside it add latency, availability dependence and the risk that losing a key means losing the data. These trade-offs are part of the design, which is why the honest statement of what is protected must be precise.

4. The localisation fallacy

The localisation fallacy is the belief that if a global provider hosts data inside the country, the data is automatically beyond foreign reach. Local hosting may solve latency, residency and some policy requirements. It does not necessarily solve control, as the operating company or its parent may remain subject to extraterritorial legal authority.

Instrument	What triggers reach	Does in-country hosting prevent it?
US CLOUD Act (2018)	Provider possession, custody or control of data	No: location is not the trigger
US FISA Section 702	Providers subject to US jurisdiction; non-US persons abroad	No. Statute lapsed 12 June 2026; certifications run to about March 2027
US Executive Order 12333	Signals intelligence outside ordinary provider compulsion	Not a hosting question; no statute or court order needed
China National Intelligence Law, Art. 7	Duty of organisations and citizens to support state intelligence work	Depends on corporate and personnel links
Russia Federal Law 152-FZ	Personal data of Russian citizens stored on servers in Russia	A localisation rule, not a shield from state access

Figure 5. Legal instruments that can create reach, and whether in-country hosting prevents them (status as at October 2026; sources in the reference list).

The mechanisms

- **US CLOUD Act (2018).** Amends the Stored Communications Act so that compelled disclosure turns on the provider's possession, custody or control of data, not on its location. It also provides for executive agreements between the United States and qualifying foreign governments [12].
- **FISA Section 702.** Authorises US intelligence agencies to direct providers to disclose communications of non-US persons reasonably believed to be abroad. The statute lapsed on 12 June 2026. Because collection runs on certifications approved in March 2026, it can continue to about March 2027, and Congress has not yet reauthorised the law [14][15].
- **Executive Order 12333.** Underpins US signals intelligence outside the United States and needs no statute or court approval; it was untouched by the 702 lapse.
- **Other jurisdictions.** China's National Intelligence Law (Article 7) obliges organisations to support state intelligence work, and Russia's Federal Law 152-FZ requires localisation of citizens' personal data on Russian servers. Their structures differ, but each can create sovereignty tensions.

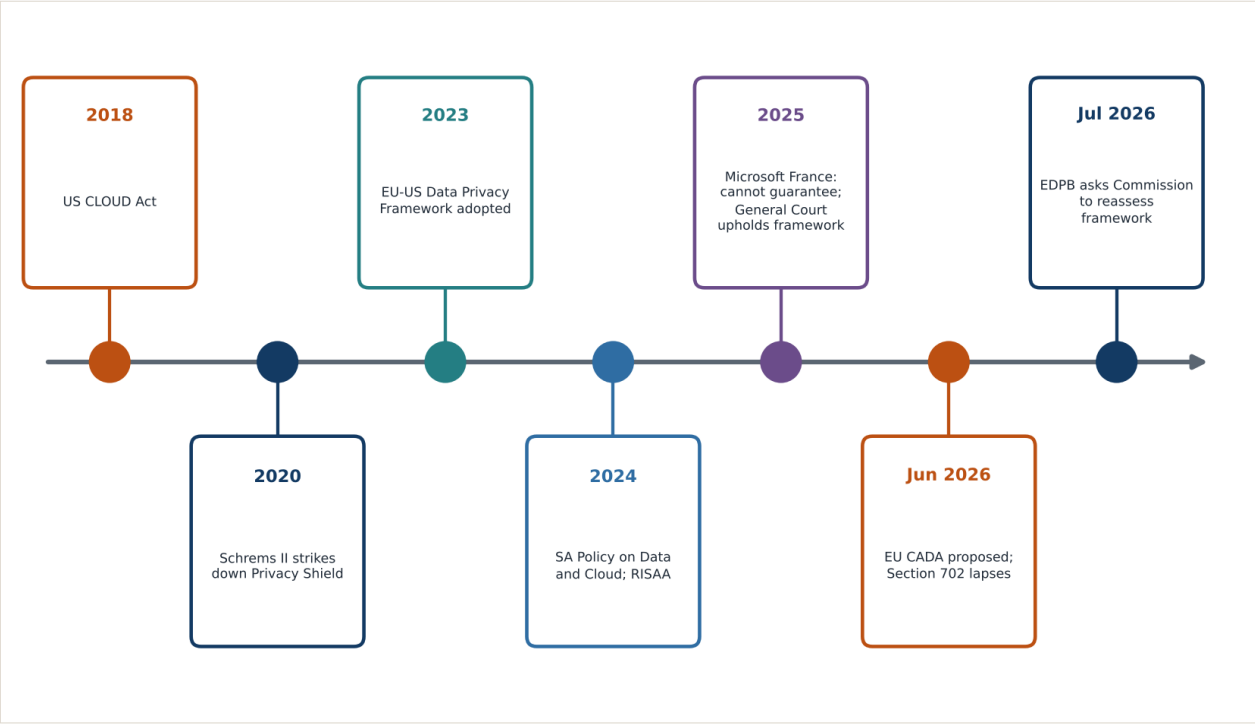


Figure 6. Selected milestones in the law of cross-border access, 2018 to 2026.

Residency versus sovereignty

The point is not that every foreign provider is unsafe or unusable. Leaders must distinguish between data residency and data sovereignty. **Residency is where the data sits. Sovereignty is who can make the data intelligible**, who can compel access, who holds the keys, who controls administrators, and who can independently verify what happened. Location still matters for latency, physical security, resilience and the reach of domestic law enforcement, so the aim is to add control to residency, not to dismiss it.

The EU's proposed four-level cloud sovereignty framework illustrates where policy is heading: its lower level concerns EU-based data processing, while higher levels add conditions on third-country control, ownership, supply chain transparency, personnel clearance and independent audit [16][17]. Africa's governments are experimenting along similar lines, for example through South Africa's policy on sovereign cloud capacity and in-country storage of national-security-related government data [20].

5. The honest formulation for government leaders

> **The honest formulation a country should use**
>
> "Our data is hosted in-country" is a true and meaningful statement about residency. "Our data is sovereign" claims legal and technical control that residency alone does not establish.
>
> A government that uses these two statements interchangeably in public communication is, often unknowingly, giving its citizens false assurance about a real and specific legal exposure.

A government can still use foreign or regional cloud infrastructure responsibly. But it should require externally controlled keys, confidential computing where appropriate, independently auditable access logs, contractual challenge processes, support-access restrictions, incident transparency, and a clear domestic or regional institution accountable for key custody and access policy.



Figure 7. A seven-layer sovereignty control stack: location is the first layer, not the last.

Choosing a key custody model

Option	Who holds the keys	What it protects	Limits
Provider-managed keys	The provider.	Theft of storage media; ordinary external breach.	The provider, and anyone who can compel it, can decrypt.
Customer-managed keys in the provider's key service	Customer controls policy; key material stays on provider infrastructure.	Separation of duties; ability to revoke.	Provider infrastructure still hosts the keys; compelled access remains plausible.
External key manager (customer-run hardware security module)	A customer or domestic institution, outside the provider.	Provider cannot decrypt without live key requests the customer can refuse or revoke.	Added latency and availability dependence; plaintext exposed during processing unless enclaves are used.
Double key encryption	Two keys; one held only by the customer.	Provider cannot read protected content.	Limits provider services such as search and analytics.
Confidential computing with attestation	Data decrypted only inside attested hardware enclaves.	Protects data in use from host administrators.	Trust in hardware vendors; operational complexity; not every service supported.

Table 5. Key custody options and their limits.

Cloud vendors and independent key-management specialists offer variants of each of these models, and the reference list at the end of this article names several. Buyers should test any model against the compelled-disclosure scenario above rather than rely on a marketing label.

What to say, and what to avoid

Statement	Accuracy	A more accurate formulation
"Our data is hosted in-country."	True if verified	A residency statement; say what is hosted, where, and under which operator.
"Our data is sovereign."	Unproven	Only after key custody, access control and an accountable institution are evidenced.
"Foreign companies cannot access our data."	Risky	Depends on key custody, support access and the provider's parent jurisdiction.
"Local law protects citizens' data."	Partly true	Local law governs processing in the country but cannot alone override a foreign order to a foreign provider.
"Citizen records are encrypted with keys held by [named institution]; the provider cannot read them; access is logged and independently audited."	Precise	The form of words to aim for, once it is true.

Table 6. Public statements and their accuracy.

6. From principle to procurement: a decision path

Principles become useful only when they change what a government buys and how it tests it. The decision path below is a practical way to match the protection to the data. It is an illustrative framework developed for this edition, not a legal standard, and should be adapted to local law.

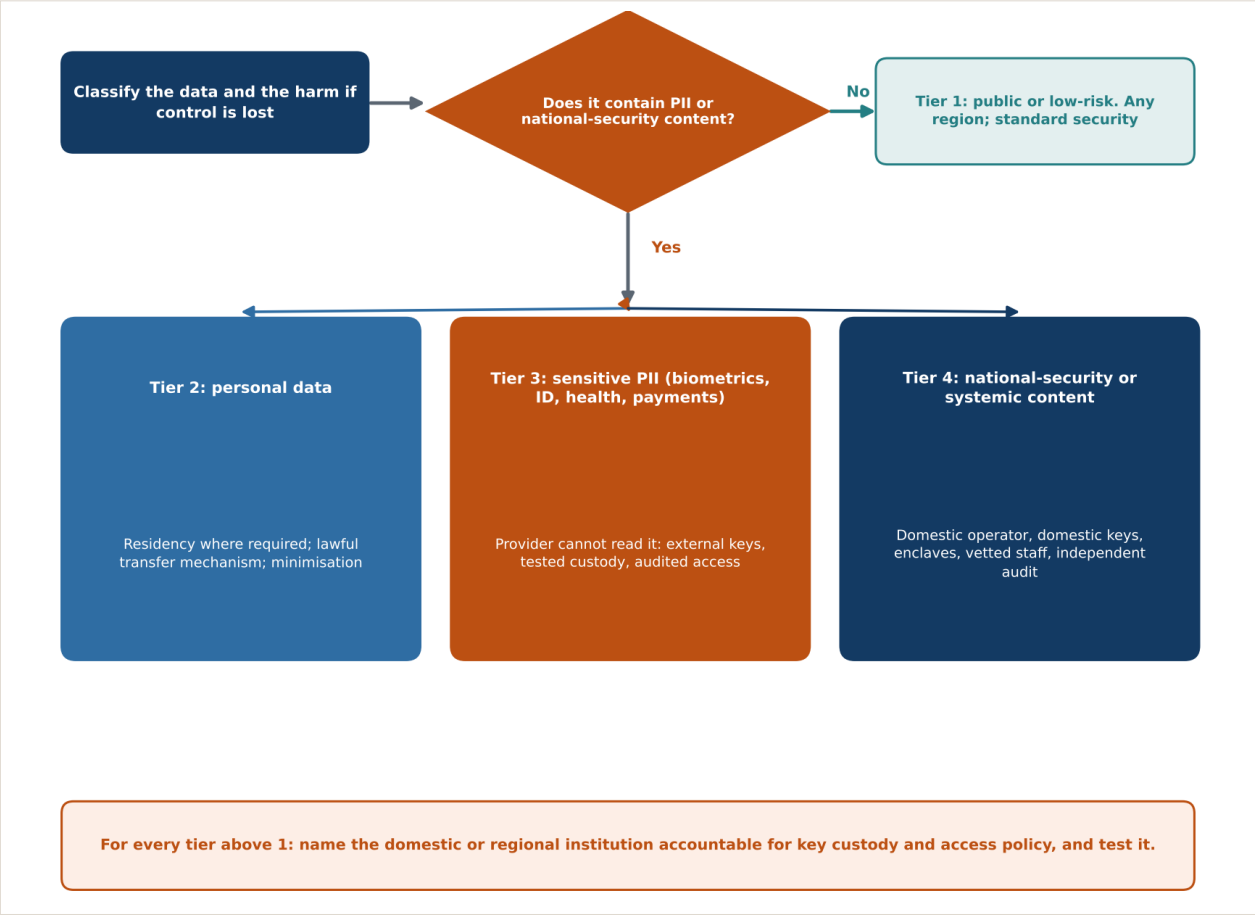


Figure 8. A four-tier decision path from data classification to architecture.

Tier	Examples	Minimum architecture	Evidence to demand
1 — Public or low risk	Open data, public content.	Any region; standard security.	Standard assurance reports.
2 — Personal data	Contact details, service usage.	Residency where required; lawful transfer mechanism; minimisation.	Data flow map; transfer assessment.
3 — Sensitive PII	Biometrics, ID numbers, health, payments, welfare, consent.	Provider cannot read data: external keys, tested custody, audited access, enclaves where appropriate.	Key custody records, attestation, independent access logs.

Tier	Examples	Minimum architecture	Evidence to demand
4 — National-security or systemic	Registry master keys, authentication roots, strategic datasets.	Domestic operator; domestic keys; enclaves; vetted staff; independent audit.	Independent audit and exercise results.

Table 7. Minimum architecture and evidence by tier.

Procurement requirements

1. **Key custody.** Keys held by a named domestic or regional institution, outside the provider's control.
2. **Confidential computing** where data in use must be protected, with attestation.
3. **Independent logs.** Access logs the provider cannot alter, available to the state.
4. **Challenge and notification.** A contractual duty to notify and challenge compelled requests to the extent the law permits.
5. **Support-access limits.** Approval, time limits and geographic restrictions for provider staff.
6. **Incident transparency.** Time-bound notification of any access outside agreed procedure.
7. **Accountable institution.** A named body answerable for key custody and access policy.
8. **Exit and portability.** Tested export and a plan to leave without the provider's cooperation.

Test it before relying on it

Run a compelled-disclosure exercise before go-live. Assume a lawful order is served on the provider's parent company. Record what the provider could produce in readable form, how long the state would take to learn of it, and whether the keys and logs behaved as designed. Repeat after significant changes. **The result, not the contract, is the evidence of sovereignty.**

> **Series bridge**
>
> The next and final article in the series addresses the open-source and digital public goods dimension: why open source is a strong start for sovereignty, why it is not the whole answer, and which technical controls make sovereignty true in practice. It builds on the control stack introduced here by asking how code that anyone can inspect can be run, updated and verified under national control.

About the author

Godfrey Kutumela (He/Him)

CISSP (MSc Information Security), CCSP, CSSLP, TOGAF, ISO 27001 LA, MDP

Executive Lead and Digital Trust Practitioner, Digital Trust Futures Foundation

Godfrey Kutumela is a globally recognised cybersecurity practitioner with over 26 years of experience shaping secure digital ecosystems across fintech, identity and public infrastructure environments. He operates at the intersection of Digital Public Infrastructure (DPI), Digital Public Goods (DPGs) and

national-scale platforms, bringing deep expertise in securing systems where the impact of failure is measured at the population level rather than the enterprise level.

- Trusted advisor to governments, foundations and ecosystem builders delivering secure-by-design DPI across Africa, Latin America and global markets.
- Core contributor to large-scale platforms including Mowali (mobile money interoperability infrastructure), Mojaloop (interoperable faster payments), MOSIP (digital identity) and Tazama (fraud systems).
- Designs and embeds independent, risk-based security practices across payment systems, identity frameworks and cross-border financial infrastructure.
- Works across policy, architecture and implementation layers, translating global standards into deployable security controls.
- Contributor to the Digital Public Goods Alliance (DPGA) Privacy Expert Group, shaping global privacy and security indicators.
- Active in open-source security, DevSecOps integration and supply chain assurance for reusable digital platforms.
- Delivered independent security reviews, penetration testing and architecture governance across critical DPI implementations.

His leadership philosophy in the DPI ecosystem is clear: security forms the foundation upon which safety and trust are built. Safety is what citizens experience in practice, and trust is the legitimacy that sustains adoption; once lost, it is difficult to restore.

About Digital Trust Futures Foundation

Digital Trust Futures Foundation is an independent, non-profit public-benefit organisation strengthening the safety, security, rights, inclusion and trustworthiness of digital public infrastructure (DPI), digital public goods (DPGs), open-source technology and AI-enabled public services. Its work is grounded in the recognition that DPI has become critical national infrastructure operating in a persistent threat environment, requiring independent, ecosystem-level assurance that goes beyond traditional approaches.

The Foundation operates outside vendor, implementer and platform incentives. It combines evidence-based cybersecurity, safety and AI-governance assurance with human-rights and child-protection expertise, and releases its tools, research and frameworks as reusable public goods rather than proprietary products — so that the value of a single engagement extends to every government, maintainer and community facing the same risk.

Digital Trust Futures Foundation NPC is registered as a non-profit company in South Africa and works across Africa and the wider Global South, with emphasis on countries and communities adopting DPI under capacity and assurance constraints.

Digital Trust Futures Foundation | Safe infrastructure. Trusted technology. Inclusive digital futures.

info@digitaltrustfuturesfoundation.org | digitaltrustfuturesfoundation.org | +27 83 680 3427

Published as a public good. This paper may be shared and quoted with attribution to Digital Trust Futures Foundation NPC. It is provided for general information and does not constitute a certification, assurance opinion or endorsement of any system, product or jurisdiction.

References and further reading

This list is organised by institutional category and reflects the regulatory and threat landscape as understood in October 2026, with the original June 2026 list retained and developments since then added. Several instruments — in particular the EU Cloud and AI Development Act, the EU–US Data Privacy Framework and US surveillance statutes — remain subject to change. Numbers in square brackets in the text refer to the numbered items below. Check secondary sources against primary texts.

Numbered references cited in the text

Ref	Source	Used for
[12]	US Clarifying Lawful Overseas Use of Data Act (CLOUD Act), 2018, amending 18 U.S.C. 2701 et seq.	Provider possession, custody or control; executive agreements.
[14]	Brennan Center for Justice, Section 702 of FISA: 2026 Resource Page (updated 27 October 2026); Congressional Research Service reports on Section 702 and the 2024 RISAA.	Lapse and reauthorisation status.
[15]	Press and analysis on the 12 June 2026 lapse and the March 2026 FISC certifications (for example The Hill, Washington Times, Fulcrum); to be checked against primary texts.	Continued collection to about March 2027.
[16]	European Commission, Tech Sovereignty Package and proposed Cloud and AI Development Act (3 June 2026), with law-firm and think-tank analyses (Jones Day; Belfer Center; Bloomsbury Intelligence and Security Institute).	Four assurance levels; legislative status.
[17]	TechPolicy.Press and Global Policy Watch analyses of the package.	Open-source preference; tiers; market openness.
[18]	Court of Justice of the EU: Latombe v Commission (T-553/23, 3 September 2025) and appeal C-703/25 P; European Data Protection Board request to the Commission (31 July 2026), as reported.	Status of the EU–US Data Privacy Framework.
[19]	French Senate inquiry, testimony of Microsoft France (10 June 2025), as reported in secondary coverage.	Provider cannot guarantee exclusion of US authorities.
[20]	Republic of South Africa, National Policy on Data and Cloud (published 31 May 2024); law-firm summaries (Bowmans).	Government data localisation; sovereign cloud.
[21]	Protection of Personal Information Act 4 of 2013, section 72.	Cross-border transfer conditions.
[22]	TechCabal (24 August 2026) and other regional reporting on Nigeria, Kenya, South Africa and Rwanda localisation.	Regional localisation rules; verify locally.

Table 8. Sources for the figures and developments cited.

United Nations and UN agencies

- UN Office for Digital and Emerging Technologies (ODET): Universal DPI Safeguards Framework and DPI Safeguards Resource Hub, co-led with UNDP.
- UN Development Programme: Digital Public Infrastructure guidance and co-stewardship of the Digital Public Goods Alliance.
- UN General Assembly: Global Digital Compact (2024) and follow-up processes.
- International Telecommunication Union: GovStack Initiative (with GIZ, Estonia and UNDP), reusable government Building Block specifications.
- UNCTAD: Digital Economy Report series on cross-border data flows and data sovereignty.
- World Bank Group: Identification for Development (ID4D) Practitioner's Guide and Principles on Identification; "Resilient, Secure and Trusted: The Next Frontier for Digital Public Infrastructure" (2025).
- World Economic Forum: "Building Security into India's Digital Public Infrastructure" (October 2025) and DPI security risk taxonomy.
- OECD: Going Digital project and DPI security and governance guidance.

European Union and European bodies

- GDPR, Regulation (EU) 2016/679, including Chapter V and Article 48.
- Cloud and AI Development Act (proposed 3 June 2026) as part of the European Technological Sovereignty Package, including the EU Open Source Strategy and Chips Act 2.0.
- EU AI Act (in force from August 2024): high-risk classification of biometric identification, social benefit determination and access to essential services.
- Digital Services Act and Digital Markets Act; NIS2 Directive.
- ENISA: cybersecurity guidance and input to the EU Cybersecurity Certification Scheme for Cloud Services.
- CJEU: Schrems II (Case C-311/18, 2020); EDPB Recommendations 01/2020 on supplementary measures.
- European Commission DG CONNECT: Cloud Sovereignty Framework.

United States

- CLOUD Act (2018); FISA Section 702; Executive Order 12333; USA PATRIOT Act Section 215; United States v. Microsoft Corp. (2018).
- NIST: Digital Identity Guidelines (SP 800-63-4); Secure Software Development Framework (SP 800-218); Cybersecurity Framework; AI Risk Management Framework.
- CISA: advisories and the Known Exploited Vulnerabilities catalog.
- US National Trade Estimate Report (2026) on foreign data localisation and sovereign cloud measures.

Other national and regional regimes

- China: Cybersecurity Law (2017), Data Security Law (2021), Personal Information Protection Law (2021) and Article 7 of the National Intelligence Law (2017).
- Russian Federation: Federal Law 152-FZ on Personal Data.
- India: Digital Personal Data Protection Act (2023) and the DEPA and Account Aggregator consent framework.
- Brazil: LGPD and the ANPD.
- Estonia: the Data Embassy concept and bilateral arrangement with Luxembourg.
- Canada: Foreign Extraterritorial Measures Act and the Canadian Sovereign Cloud Initiative.
- African Union: Digital Transformation Strategy for Africa 2020–2030; AfCFTA digital trade provisions.
- ASEAN: Digital Masterplan 2025.

Cloud and key-management providers

- Microsoft: Azure Sovereign Cloud, EU Data Boundary, Managed HSM external key options and confidential computing.
- Google Cloud: Cloud External Key Manager and Cloud KMS.
- Amazon Web Services: KMS, Nitro Enclaves and the Digital Sovereignty Pledge.
- Thales and Utimaco: guidance on BYOK, HYOK, external key management and double key encryption.
- OpenSSF and the Linux Foundation: Scorecard and SLSA.

DPI and DPG frameworks and communities

- Digital Public Goods Alliance: DPG Registry and DPG Standard.
- MOSIP, Mojaloop, Estonia X-Road (NIIS), Centre for Digital Public Infrastructure, Co-Develop Fund, Digital Impact Alliance Principles for Digital Development, and the Gates Foundation DPI programme, including the Upanzi Network.

Threat intelligence and standards

- CrowdStrike 2026 Global Threat Report; MITRE ATT&CK; OWASP API Security Top 10; CIS Benchmarks; ISO/IEC 27001 and 42001; CSIS Significant Cyber Incidents tracker; IBM Cost of a Data Breach Report.

Verification notes

- Legislative status in the United States and the European Union was changing as this edition was prepared. Confirm current status before citing.
- Some facts come from secondary reporting. This article is classified as Public; official use should rely on primary legal texts and counsel.